Praising Y Harris Ratnam

Application Security & AI Security · Python

B.Tech CSE (Cybersecurity), IIIT Kottayam, 2024–2028 · CGPA 7.9/10
praisingharris@gmail.com • github.com/Pyhroff • linkedin.com/in/praising-harris-8a3320330 • pypi.org/user/Pyhroff

SUMMARY

Cybersecurity undergraduate who builds and measures static scanners for the inputs AI agents trust: MCP tool metadata, agent memory files and RAG documents. 4 pull requests merged and shipped in releases of SQLGlot, SQLFluff and LiteLLM; 4 security packages published on PyPI; ran a hand-labelled study of 135 public MCP servers and reported the null result (no tool poisoning found in the wild).

OPEN-SOURCE CONTRIBUTIONS

Merged and shipped in releases Oct 2026

- **tobymao/sqlglot #8780** (in v30.25.0): fixed one `exp.DataType` node being shared across several casts in `Parser._replace_lambda` each cast now gets its own copy, restoring the one-parent-per-node AST invariant that in-place transforms rely on.
- **sqlfluff/sqlfluff #8901, #8902** (in 4.5.0): removed the unsupported `FLUSH` statement from the Apache Doris and StarRocks grammars, which were inheriting it from MySQL; reworked both after maintainer review.
- **BerriAI/litellm #47091**: normalised a string `stop` parameter to a list for Cohere `stop_sequences`, which the Cohere API rejected.

Open, under review Oct–Nov 2026

- **BerriAI/litellm #47105**: authorization fix for keys and teams with access groups but an empty model list (issue #46951). It now fails closed (403) instead of allowing every model. Revised after a maintainer requested changes; added unit tests. Related: #47106, #47107.
- **sqlfluff/sqlfluff #8900** (approved by a maintainer, awaiting merge): `FORMATS` / `POLICIES` keywords for the ANSI grammar.
- **crewAIinc/crewAI #8240**: cursor pagination (`nextCursor`) for MCP `list_tools` / `list_prompts` plus #8242, #8244, #8245 (task context on guardrail retries, Redis URL decoding, newline counting).
- **PrefectHQ/fastmcp #6063**: wall-clock timeout and callback cap for the Monty sandbox provider. **graphql-python/graphene #1610**: lazy type references for `Connection.Meta.node`.

PROJECTS

aisec-suite — CI security gate for AI-agent inputs · Python, GitHub Actions, SARIF PyPI: aisec-suite 0.4.0

- One `aisec scan` command runs mcpaudit, memsentry and ragsentry over a repo and emits SARIF/JSON with `--fail-on` exit codes; ships as a pinned, reusable GitHub Action.
- Structural tool-poisoning detector (decodes hidden Unicode and base64/hex, then scores model-directed cues): **48.1% recall** on 54 held-out synthetic attacks (a naive regex scored 0%) at a **0.03% false-positive rate** (1 of 3,974 real tool descriptions). The held-out set was run twice, and the README documents this.
- AST taint reachability (`--reach`) checks whether a tool parameter actually reaches a file, command, network or SQL sink. Across 120 hand-labelled findings it never wrongly dismissed a real one; it gives a verdict on about 9% of them.

MCP server security study + mcpaudit · static analysis, hand labelling, Wilson CIs PyPI: pyhroff-mcpaudit 0.8.0

- Scanned 135 public MCP-server repos (90 at pinned SHAs, plus a fresh 45 for validation) and hand-labelled findings. Found no real tool poisoning; 37.5% of the scanner's HIGH permission-scope findings were accurate.
- Rewrote the scope rules in mcpaudit v0.7. On the blind-labelled fresh corpus, precision went from **40% to 72.7%** with all 16 true findings kept (pooled across both untuned samples: 38.8% to 69.4%, recall 80.6%). v0.8 added SARIF export.

memsentry · ragsentry — static scanners for poisoned agent memory and RAG documents PyPI: memsentry 1.2.0 · pyhroff-ragsentry 1.1.0

- Flag persistent instruction injection, hidden payloads and dependency manipulation in `CLAUDE.md` / `.cursorrules`-style context files and retrieval documents. On 170 real context files, memsentry 1.2.0 cut false positives from 61 to 5.

SOC Parallax — behavioural detection platform · FastAPI, Neo4j, Next.js github.com/Pyhroff/soc-parallax

- Per-entity baselines, an attributable risk score and MITRE ATT&CK mapping from a versioned rulebook. On 278 real EVTX attack samples, 29.5% reach medium severity or higher (27.3% on the held-out half). Nothing reaches high on held-out benign data. This replaced an earlier, inflated figure.

OSIRIS — personal AI assistant runtime I use daily · Python, SQLite, embeddings github.com/Pyhroff/osiris

- Eight model providers behind one router with automatic failover; nine keyword-routed agents with per-agent tool scoping (about 40 tools); embedding-based memory with a keyword fallback.

EXPERIENCE, EDUCATION & SKILLS

CyberOps — Cybersecurity Intern (remote) May–Jul 2025

Studied web and network VAPT methodology.

TryHackMe ongoing

Top 2% globally; 177 rooms (privilege escalation, Linux, networking).

IIIT Kottayam — B.Tech CSE (Cybersecurity) 2024–2028

CGPA 7.9/10 · DSA, Operating Systems, DBMS, Computer Networks, OOP, Cryptography.

Languages: Python (asyncio, `ast`), SQL, C/C++, Bash

Security: static analysis, SARIF, OWASP Top 10, MCP / prompt-injection and tool-poisoning threat models, MITRE ATT&CK, VAPT

Tools: Git, GitHub Actions, pytest, Docker, Linux, PostgreSQL, FastAPI, Neo4j, PyPI trusted publishing